T10 OWASP TOP10
アプリケーションセキュリティリスク – 2017

A1:2017-インジェクション
SQLインジェクション、NoSQLインジェクション、OSコマンドインジェクション、LDAPインジェクションといったインジェクションに関する脆弱性は、コマンドやクエリの一部として信頼されないデータが送信される場合に発生します。攻撃コードはインタープリタを騙し、意図しないコマンドの実行や、権限を有していないデータへのアクセスを引き起こします。

A2:2017-認証の不備
認証やセッション管理に関連するアプリケーションの機能は、不適切に実装されていることがあります。不適切な実装により攻撃者は、パスワード、鍵、セッショントークンを侵害したり、他の実装上の欠陥により、一時的または永続的に他のユーザーの認証情報を取得します。

A3:2017-機微な情報の露出
多くのウェブアプリケーションやAPIでは、財務情報、健康情報や個人情報といった機微な情報を適切に保護していません。攻撃者は、このように適切に保護されていないデータを窃取または改ざんして、クレジットカード詐欺、個人情報の窃取やその他の犯罪を行う可能性があります。機微な情報は特別な措置を講じないでいると損なわれることでしょう。

A4:2017-XML外部エンティティ参照(XXE)
多くの古くて構成の悪いXMLプロセッサーにおいては、XML文書内の外部エンティティ参照を指定することができます。外部エンティティは、ファイルURIハンドラ、内部ファイル共有、内部ポートスキャン、リモートコード実行、DoS（サービス拒否）攻撃により、内部ファイルを漏えいさせます。

A5:2017-アクセス制御の不備
権限があるもののみが許可されていることに関する制御が適切に実装されていないことがあります。攻撃者は、このタイプの脆弱性を悪用して、他のユーザのアカウントへのアクセス、機密ファイルの表示、他のユーザのデータの変更、アクセス権の変更など、権限のない機能やデータにアクセスします。

A6:2017-不適切なセキュリティ設定
不適切なセキュリティの設定は、最も一般的に見られる問題です。これは通常、安全でないデフォルト設定、不完全またはアドホックな設定、公開されたクラウドストレージ、不適切な設定のHTTPヘッダ、機微な情報を含む冗長なエラーメッセージによりもたらされます。すべてのオペレーティングシステム、フレームワーク、ライブラリ、アプリケーションを安全に設定するだけでなく、それらに適切なタイミングでパッチを当てることやアップグレードをすることが求められます。

A7:2017-クロスサイトスクリプティング(XSS)
XSSの脆弱性は、適切なバリデーションやエスケープ処理を行っていない場合や、HTMLやJavaScriptを生成できるブラウザAPIを用いているユーザ入力データで既存のWebページを更新する場合に発生します。XSSにより攻撃者は、被害者のブラウザでスクリプトを実行してユーザーセッションを乗っ取ったり、Webサイトを改ざんしたり、悪意のあるサイトにユーザーをリダイレクトします。

A8:2017-安全でないデシリアライゼーション
安全でないデシリアライゼーションは、リモートからのコード実行を誘発します。デシリアライゼーションの欠陥によるリモートからのコード実行に至らない場合でさえ、リプレイ攻撃やインジェクション攻撃、権限昇格といった攻撃にこの脆弱性を用います。

A9:2017-既知の脆弱性のあるコンポーネントの使用
ライブラリ、フレームワークやその他ソフトウェアモジュールといったコンポーネントは、アプリケーションと同等の権限で動いています。脆弱性のあるコンポーネントが悪用されると、深刻な情報損失やサーバの乗っ取りにつながります。既知の脆弱性があるコンポーネントを利用しているアプリケーションやAPIは、アプリケーションの防御を損ない、様々な攻撃や悪影響を受けることになります。

A10:2017-不十分なロギングとモニタリング
不十分なロギングとモニタリングは、インシデントレスポンスに組み込まれていないか、非効率なインテグレーションになっていると、攻撃者がシステムをさらに攻撃したり、攻撃を継続できるようにし、ほかのシステムにも攻撃範囲を拡げ、データを改竄、破棄、破壊することを可能にします。ほとんどのデータ侵害事件の調査によると、侵害を検知するのに200日以上も要しており、また内部機関のプロセスやモニタリングからではなく、外部機関によって検知されています。

■OWASP Top10とは
The Open Web Application Security Project（オワスプ）が発表しているWebアプリケーションでよくみられる脆弱性のTop10です。
前バージョンから4年以上経ち、世の中が大きく変化した中で、専門企業や研究者から提供された調査データに基づき、最新順位にアップデートされました。OWASP Top10の主要な目的は、開発者、デザイナー、アーキテクト、マネージャ、組織などに対して最も一般的かつ最も重要なWebアプリケーションセキュリティの弱点の影響について教育することです。Top10やその他のOWASPのリソースには、あなたがその立場に応じてどうセキュリティを進めていくべきか、さまざまなアドバイスが記載されていますので、ぜひご活用ください。

■OWASP KANSAIとは
Webセキュリティを取り巻く問題を解決する国際的なコミュニティOWASPの関西支部として2014年に設立されました。
会社・立場・役割を超えて、それぞれができることを実践することでWebを確かなものにしていく仲間を増やす場です。
OWASP KANSAIが開催するチャプターミーティングで情報交換を行い、お互いを高め合っていきましょう。

ウェブをたしかなもんに

オワスプカンサイ

https://www.owasp.org/index.php/Kansai
#owaspkansai